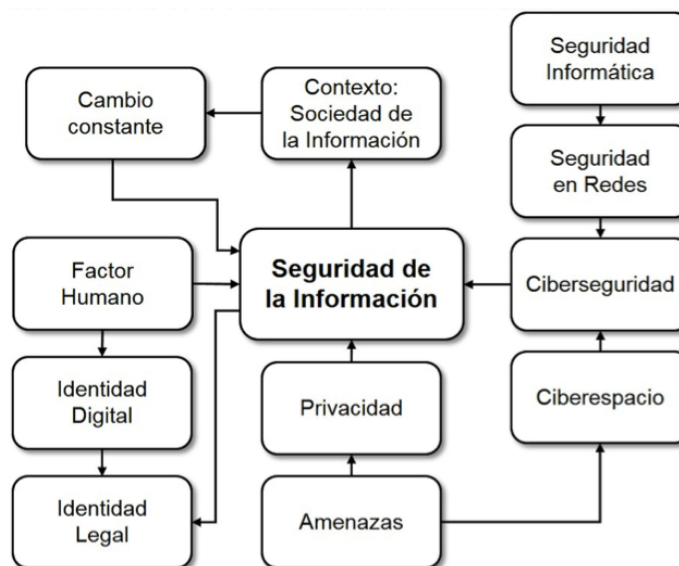


# Unidad de Aprendizaje 1 - Seguridad de la información: una visión integral

## Objetivos y esquema básico de contenidos de la unidad:

- Conocer los aspectos básicos e impulsores de la situación de cambio provocada por la irrupción de las tecnologías de la información en todos los ámbitos de la sociedad.
- Conocer y entender los principios básicos, definiciones y conceptos relativos a la seguridad de la información, la seguridad informática, la seguridad en TIs y la ciberseguridad.
- Conocer los elementos que configuran la identidad y el rastro digitales, y los fundamentos de la firma electrónica y el empleo de certificados digitales y el DNI electrónico.
- Reflexionar acerca de las principales amenazas y desafíos en relación con el advenimiento de la sociedad de la información y su repercusión en los diferentes ámbitos de la actividad humana.



## **Contextualización: Sociedad de la información (1/2)**

**Situación actual:** Cambio Constante

**Impulsores del cambio:** Estándares y tecnologías de bajo coste

**Factores tecnológicos:**

- Internet como red global y ubicua
- Polarización de los entornos software
- Evolución hacia la computación móvil
- La nube, sistemas conectados e Internet de las cosas (IoT)
- Big Data, inteligencia artificial (IA) y robótica

**Factores de tipo humano y social:**

Nuevas formas de interacción motivadas por los factores tecnológicos y especialmente, por la irrupción de la web 2.0 y las redes sociales:

- Nuevos entornos de comunicación
- Redes sociales y plataformas digitales como fuente de (des)información

## Contextualización: Sociedad de la información (2/2)

### Factores económicos y políticos:

- Industria del Cibercrimen: supera al tráfico de drogas, al tráfico de armas o a la trata de personas
- Polarización de los gigantes tecnológicos: GAFAM y BATX controlan actividad mundial
- Globalización de la economía y precarización del empleo: estrechamiento de clases medias.
- Guerra fría tecnológica: EEUU y China, con la supremacía mundial en juego (China, derechos humanos?)
- Ciberespacio, ciberguerra y conflictos híbridos: quinto dominio, guerras no declaradas

### ¿Hacia dónde vamos? – **Industria 4.0 – La cuarta revolución industrial**

Klaus Schwab, fundador y presidente Foro Mundial de Davos, libro homónimo

- Primera (S. XVIII, finales del XIX): máquina de vapor, sociedad fabril, textil y acero
- Segunda (finales XIX, 2ª GM): acero, petróleo, electricidad, producción en masa, teléfono, automóvil
- Tercera (finales XX, hoy): microelectrónica, ordenador personal, Internet, móviles, web 2.0, RRSS, nube
- Cuarta (ahora, ¿?): revolución digital, integración de la tecnología en las sociedades; robótica, IA, nanotecnología, computación cuántica, IoT, blockchain, impresión 3D y vehículos autónomos.

## Seguridad de la información: Definiciones y conceptos básicos (1/5)

**Seguridad Informática** es la disciplina que se ocupa de diseñar las normas, procedimientos, métodos y técnicas orientados a proveer condiciones seguras y confiables para el procesamiento de datos en sistemas informáticos.

**Seguridad en TIs** es la disciplina que se ocupa de diseñar las normas, procedimientos, métodos y técnicas orientados a proveer condiciones seguras y confiables para el procesamiento y la transmisión de datos entre sistemas informáticos.

**Ciberseguridad** es el conjunto de actuaciones orientadas a asegurar, en la medida de lo posible, las redes y sistemas que constituyen el ciberespacio. Y a su vez,

**Ciberespacio** es el espacio virtual que engloba todos los sistemas TIC, tanto sistemas de información como de control industrial.

Una organización puede hablar de seguridad en TIs, pero a nivel nacional o supranacional, el concepto adecuado será **ciberseguridad**. La ciberseguridad contempla hogares, empresas, industrias, administraciones, infraestructuras críticas, defensa, etc.

En los últimos años, el concepto de seguridad en TIs, asociado al ámbito meramente tecnológico, se ha ampliado con la aparición de un concepto más integral: La seguridad de la información (Information Security)

## Seguridad de la información: Definiciones y conceptos básicos (2/5)

MAGERIT V3 define la seguridad de la información como:

*“**Seguridad de la información** es la capacidad de las redes o de los sistemas de información para resistir, con un determinado nivel de confianza, los accidentes o acciones ilícitas o malintencionadas que comprometan la **disponibilidad, integridad y confidencialidad de los datos** almacenados o transmitidos y de los servicios que dichas redes y sistemas ofrecen o hacen accesibles”*

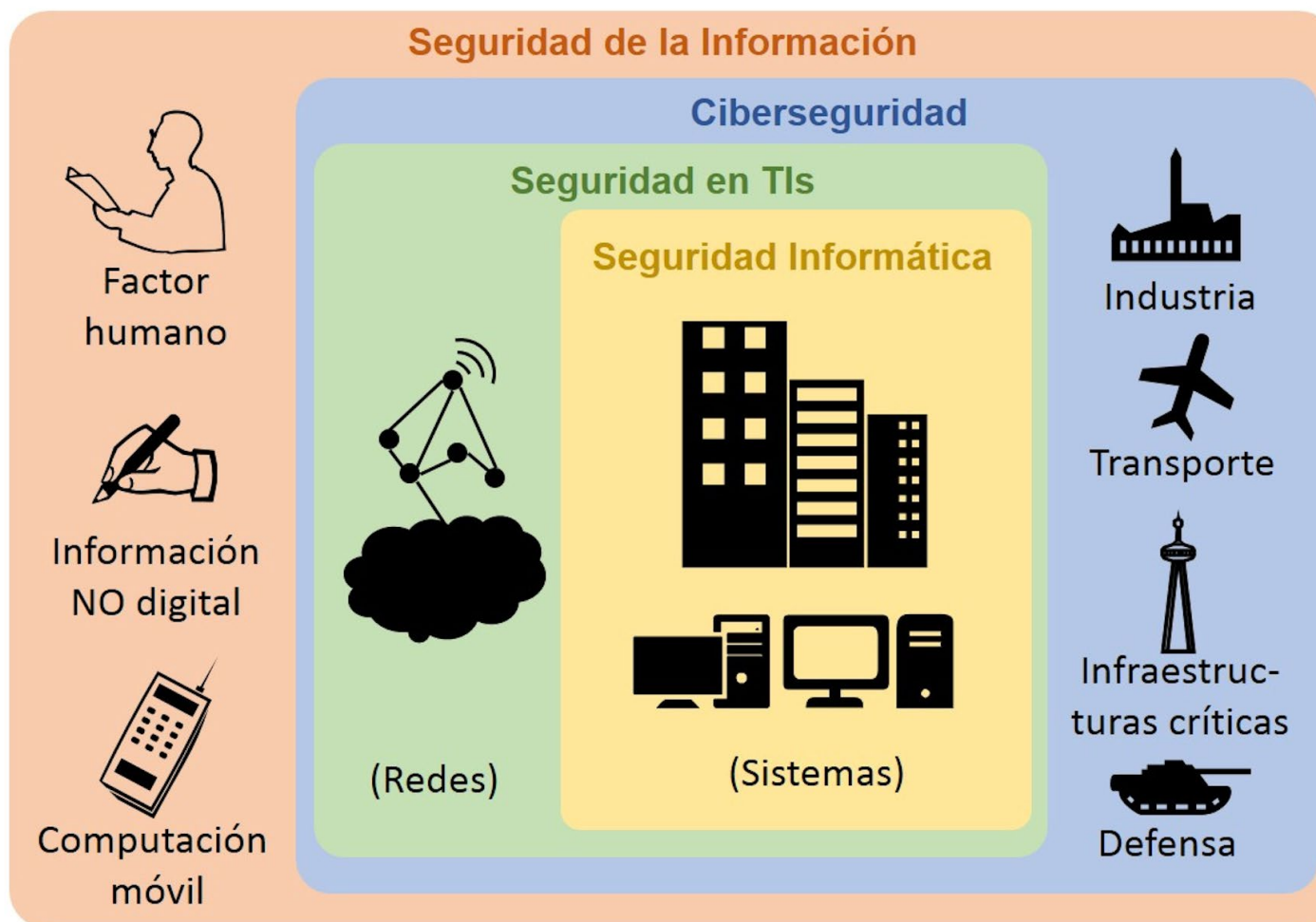
- **Disponibilidad:** sin duda, la característica más importante. La información debe estar disponible cuando sea necesario y por quien esté autorizado a ello.
- **Integridad:** es la característica de la información relativa a su fiabilidad. Se trata de evitar que la información sea alterada o modificada sin autorización
- **Confidencialidad:** la información sólo debe ser accesible por las personas, programas o sistemas autorizados a ello, evitando accesos no autorizados, bien sea de forma casual o intencionada

El estándar ISO 27000 la define igual, incorporando dos nuevas dimensiones:

- **Autenticación:** Permite garantizar que el autor de cierta información sea quién dice ser
- **No Repudio:** entre dos o más agentes. Imposibilidad de que alguno pueda negar que haya participado en dicha transmisión. Dos variedades: en **origen** y **destino**

# Seguridad de la información: Definiciones y conceptos básicos (3/5)

## Ámbitos de la seguridad



## Seguridad de la información: Definiciones y conceptos básicos (4/5)

**Datos:** Son los símbolos que representan hechos, situaciones, condiciones o valores. Suponen la materia prima para la producción de información.

**Información:** Es el resultado de procesar, transformar o interpretar datos. **Supone un elemento de valor para el individuo y para la organización**

**Daño:** Perjuicio que se produce a consecuencia de un fallo en el sistema, bien sea fortuito o provocado.

**Ataque:** Acción de provocar un daño a un sistema de forma intencionada

**Riesgo:** Relación entre la magnitud del daño y la probabilidad de que dicho daño ocurra.

**Amenaza:** situación de daño cuyo riesgo de producirse es significativo

**Vulnerabilidad:** deficiencia de un sistema susceptible de producir, fortuita o intencionadamente, un fallo en el mismo.

**Activo:** Un elemento que posee valor para la organización.

## Seguridad de la información: Definiciones y conceptos básicos (5/5)

Tradicionalmente, el ámbito de la **seguridad informática** (o Seguridad en TIs) ha puesto su énfasis en la respuesta ante amenazas debidas a los ataques por explotación de vulnerabilidades. Posteriormente, se incorporó como disciplina el **análisis de riesgos**, con tres ejes principales: los **activos** (bienes de la organización o individuo), las **vulnerabilidades** y las **amenazas**.

**La seguridad de la información** conlleva una visión más amplia en el proceso de análisis de riesgos. Se integran aquí, además de los ejes tradicionales (activos, vulnerabilidades y amenazas), los riesgos propios de la organización (organizacionales, operacionales, físicos y de TIs). Integra el **factor humano**.

Así, **La seguridad de la información** se centra en garantizar la **disponibilidad, integridad, confidencialidad, no repudio y autenticación de la información**, con independencia del medio físico en que se almacene o transporte: digital, impreso, etc.

**Desde la perspectiva del negocio:** la seguridad de la información es la **protección de la información** de un rango amplio de **amenazas** para **garantizar la continuidad del negocio, minimizar el riesgo comercial y maximizar el retorno de la inversión**.



# Principios básicos de la seguridad

## 1.- La seguridad no es un producto. Es un PROCESO. Ciclo de Vida:

- Diseño
- Transición (puesta en marcha)
- Operación (día a día)
- Actualización y optimización (procesos de mejora del servicio)

## 2.- La Seguridad plena es una utopía

Esto afecta a todas las etapas:

- En el **diseño**, minimizando la “superficie de ataque”: *“Todo lo que no está explícitamente permitido, está prohibido”*.
- En el **desarrollo y puesta en explotación**: considerando posibles **vulnerabilidades** y **amenazas**, así como garantizando los principios o **dimensiones**
- En los **procedimientos** y normas de uso: concretando qué se puede hacer y qué no.
- En el uso diario: mediante **políticas, revisiones**, etc.

## 3.- La seguridad es una cadena y, como tal, romperá por el eslabón más débil

El **factor humano** (fallos debidos a negligencias o desconocimiento) resulta ser, con demasiada frecuencia, el elemento más débil del conjunto.



## **Preguntas clave: qué proteger, contra quien, cómo y hasta donde**

### **¿Qué queremos proteger?**

**Inventario de activos**, donde un “activo” será todo elemento físico, lógico o humano que conforma el sistema que queremos proteger:

- Hardware, Software, Equipos de Comunicaciones, Bases de Datos, Personal
- Otros: contratos de mantenimiento, protocolos de actuación, etc.

### **¿Contra quién nos queremos proteger?**

- Análisis de los perfiles de los posibles atacantes
- ¿Debemos protegernos de nosotros mismos?

### **¿Cómo lo vamos a proteger?**

- Identificar elementos, tecnologías, pautas, normas, procedimientos y buenas prácticas que han de ser aplicados para garantizar los principios de la Seguridad de la Información
- Identificar previamente las amenazas y las posibles defensas

### **¿Hasta dónde lo queremos proteger?**

- Los métodos modernos de **evaluación cuantitativa de riesgos**, permitirán establecer el punto de compromiso adecuado entre el valor de lo que se desea proteger y el coste total de la inversión

## Diferentes enfoques de la seguridad de la información

- Centrado en la **Normativa** que aplica en la empresa. En el caso de España, la normativa básica se centra en:
  - Ley orgánica de protección de datos de carácter personal (LOPDyGDD)
  - Ley de servicios de la sociedad de la información y comercio electrónico (LSSICE)
  - Ley de firma electrónica
  - Ley de propiedad intelectual (LPI)
  - Ley general de telecomunicaciones
- Centrado en el **negocio**: Obtención de un nivel adecuado de seguridad en la organización, aportando gestión, valor y posibilidad de recuperación.
- Enfocado hacia las **amenazas tecnológicas**: Hacking, malware, fuga de información, ingeniería social, etc.

En la práctica, para lograr una **concepción integral de la seguridad** será necesario considerar estas **tres** vertientes (**normativa, negocio y amenazas tecnológicas**), plasmando luego el resultado en la **política de seguridad de la organización**.

## Seguridad vs privacidad: en busca del equilibrio

1948 – ONU – Declaración universal de los derechos humanos: derecho a la **privacidad**.

1978 – Constitución Española (Art. 18.4): La ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos.

1992 – LORTAD      1998 – Ley general de las telecomunicaciones      1999 – LOPD    2018 - LOPDyGDD

La **privacidad** en sistemas digitales exige el empleo de **criptografía**.

Pero... la globalización del terrorismo y la Ley de Moore (duplicación capacidad TIs cada dos años) pueden motivar a los gobiernos a limitar el derecho a la privacidad

EEUU: 1991 – Chip Clipper – Phil Zimmermann – Desarrollo del PGP – Acusación de exportación de material militar

Europa: 1993 – Iniciativa de Directiva Europea – Claves privadas bajo control gubernamental

1996 – La criptografía deja de ser material militar

**China** censura Internet, Google lo acepta, 2M cámaras reconocimiento facial en China, Rusia planea Internet propia, China aspira a primera potencia mundial... y **no respeta los derechos humanos**

**Necesidad de garantizar la privacidad... suponiendo que un gobierno democrático, deje de serlo.**

## Visión integral de la seguridad (1/2)

### 1.- El factor humano: Seguridad en el personal

Eslabón más débil – 70% de los incidentes son internos – Escasa o nula cultura de seguridad

Medidas básicas: Formación, acuerdos de confidencialidad y seguimiento de personal que realiza tareas críticas

### 2.- Seguridad física y del entorno

La protección mediante barreras físicas y mecanismos de control, de los elementos tangibles de un sistema de Tecnologías de la Información. Se trata de considerar tanto las amenazas provocadas por personas, como por aquellas que tienen su origen en fenómenos naturales

Especial atención a la seguridad física de cualquier componente (repetidor Wifi, Switch, etc.) y a las técnicas de ingeniería social.

### 3.- Seguridad lógica

Aplicación de barreras y procedimientos que **protejan** el acceso a los datos de forma que sólo sean accesibles por las personas autorizadas

Objetivos fundamentales: Delimitar acceso a aplicaciones y datos, disponibilidad ante fallos

Resulta imprescindible un **equilibrio** entre fortaleza y usabilidad, entre coste y complejidad

## Visión integral de la seguridad (2/2)

### 4.- Seguridad organizativa. Políticas de seguridad

De la necesidad de formalizar el marco de trabajo relativo a la Seguridad de la Información, aparece el concepto de política de seguridad de la organización:

“Un conjunto de normas que deben cumplirse por todas las personas que tengan acceso a cualquier información y/o tecnología de una organización”

Ha de ser:

- **Abarcable:** debe poder implantarse de forma efectiva
- **Inteligible:** tanto a nivel de conceptos como de las implicaciones de no cumplir sus directrices
- **Obligado cumplimiento:** incluirá procesos de auditoría para detectar posibles desviaciones
- **Concreción de responsabilidades:** delimitará los roles necesarios y sus responsabilidades
- **Asequible:** no debe entorpecer el trabajo
- **Mejorable:** incorporará mecanismos de autoevaluación y actualización

## Seguridad a través de la oscuridad vs Seguridad a través del conocimiento

Criptografía: escritura oculta. Aplicaciones militares: Alto secreto

Hasta la era digital, todos los sistemas de cifrado se basaban en el secreto del sistema de cifrado empleado

Primeros sistemas digitales: secretos y más secretos. Seguridad: basada en la oscuridad informativa.

**La seguridad por oscuridad** es la filosofía en base a la que se considera que una aplicación informática será segura en la medida en que su **código interno no sea difundido**

Primeros sistemas criptográficos: basados en el **secreto**. **Ineficaces**: *“todo lo que un sólo hombre sea capaz de esconder, otro lo desvelará*

**Seguridad basada en el conocimiento: Principio de Kerckhoff (1880)**: *“un criptosistema debe ser seguro, incluso si todo lo relacionado con el funcionamiento del sistema, excepto la clave, es de conocimiento público”*.

Nuevos algoritmos criptográficos: concurso público. Criptoanálisis constante.

# Identificación y Autenticación

**Autenticación:** identificación exenta de dudas

**Factores de autenticación:** algo que se sabe, algo que se tiene y algo que se es

- Factor de **conocimiento**: algo que se **sabe** (nombre, apellidos, DNI, fecha de nacimiento, nombre de usuario, contraseña, PIN, etc.)
- Factor de **posesión**: algo que se **tiene** (DNI, pasaporte, teléfono móvil, correo electrónico, número de teléfono, tarjeta criptográfica, claves criptográficas, etc.)
- Factor de **existencia**: algo que se **es** (algún rasgo biométrico que nos identifique unívocamente, como el iris, la huella dactilar, rasgos faciales, ADN, etc.)

La **identificación** usualmente se realiza con **un solo factor**, la **autenticación** requiere **más de uno**.

Autenticación de dos factores como estándar.



## Identidad Digital. Rastro Digital. Metadatos

Desde la primera cuenta de acceso (usuario/contraseña) hasta la gestión de múltiples identidades digitales, dejamos un **rastro digital** (cuentas de correo, perfiles y fotos en redes sociales, web personal, opiniones vertidas en foros, conjunto de búsquedas en google, compras realizadas, etc.). La **identidad digital** será la agregación de este rastro digital.

- **La red no olvida (perdurabilidad de los datos)**
  - ¿Cómo manejar los problemas de privacidad asociados?
- **El rastro digital nos hace vulnerables**
  - La manipulación como herramienta de marketing

**Metadatos:** Pueden plantear serios problemas de seguridad.

## Hacia una identidad “legal”: DNIE y certificados digitales

España ha sido pionera en la implantación de un verdadero sistema nacional de identidad digital. DNIE (2006):

- Identidad digital
- Firma electrónica avanzada
- Mejora en el servicio al ciudadano: entrega inmediata

### Aproximación desde el punto de vista legal:

La Ley 59/2003 de 19 de diciembre define la firma electrónica como “el conjunto de datos en forma electrónica, consignados a otros o asociados con ellos, que pueden ser utilizados como medios de identificación del firmante”. Dentro de la ley se distinguen dos tipos de firma electrónica:

- **Firma electrónica avanzada:** es aquella que permite identificar al firmante y detectar cualquier cambio ulterior de los datos firmados.
- **Firma electrónica reconocida:** se considera como tal a la firma electrónica **avanzada** basada en un certificado digital reconocido y generada mediante un dispositivo seguro de creación de firma.

Tanto las firmas avanzadas (certificados de software) como las reconocidas (DNIE) tendrán respecto a los datos consignados en forma electrónica, el mismo valor que la firma manuscrita en relación con los consignados en papel.

## Un futuro cambiante. Nuevos desafíos de seguridad

Internet – capacidad de transformación – de sistema anti ataque nuclear a red global y ubícua

Web 1.0, web 2.0, web semántica, redes sociales, ubicuidad de acceso, IoT, cloud computing...

Infraestructuras críticas – ciberseguridad - ciberespacio

Es necesario **redefinir** los conceptos de seguridad de la información, ampliar las dimensiones existentes y replantear **buenas prácticas, políticas y estándares**. Se habla de una “seguridad global”, sin límites geográficos. Pero, unos (gobiernos) y otros (corporaciones – tú eres el producto) tendrán (tienen) la terrible tentación de romper el **equilibrio entre seguridad y privacidad**.

La **desinformación** como **amenaza** que socava la **confianza** de los **ciudadanos** en el **sistema** (guerra asimétrica)

Algo que hasta ahora se había respetado: la **neutralidad** de Internet, también está en peligro.

No obstante: las TIs ofrecen respuestas que alivian problemas derivados de su propia implantación.

La Red está creando una **inteligencia colectiva**. Nunca la humanidad había dispuesto de algo semejante.

**Esto se pone realmente interesante.**